



Bocconi



POLITECNICO
MILANO 1863

SCUOLA DI INGEGNERIA INDUSTRIALE
E DELL'INFORMAZIONE

Methods Project

Ransomware Risk in Healthcare: A Bayesian Network Approach

Group Number: 7

Components: **Francesca Falco** [REDACTED]
Guendalina Nardi [REDACTED]
Tiziano Rossi [REDACTED]
Benedetta Tesi [REDACTED]

Professor: **Alessandro Sanzeni, Geraud Desazars**

Academic Year: 2026-27

Contents

1	Introduction	1
1.1	Context	1
1.2	Research question & Data	1
1.3	Modelling Strategy	1
2	Model	1
2.1	Model’s core	1
2.2	Assumptions	2
2.3	Weaknesses	3
3	Scenarios	4
3.1	Scenario 1: “Worst and Best Case for a Healthcare Organisation”	4
3.2	Scenario 2: “Prevention vs Resilience”	5
3.3	Scenario 3: “Paying Under Pressure”	5
3.4	Scenario 4: “Aftermath Analysis”	5
4	Conclusions	6
	Appendix A. Bayesian Network Model Details	7
	Appendix B. Scenario Results	18
	List of Figures	29
	Bibliography	30

1 Introduction

1.1 Context

Ransomware is a form of cyberattack in which malicious software blocks access to systems or data, usually through encryption, in order to extort payment from the victim. Over time, it has evolved from a relatively simple form of digital extortion into one of the most disruptive and financially damaging cyber threats, affecting organisations across many sectors. Healthcare is particularly vulnerable because hospitals and other healthcare organisations rely on interconnected digital infrastructures, medical technologies, external providers, sensitive patient data, and time-critical processes. As a result, a successful ransomware attack may generate consequences that extend well beyond financial loss, including operational disruption, treatment delays, data compromise, regulatory consequences, reputational damage, and high recovery costs.

1.2 Research question & Data

Against this background, the project examines the likelihood of a successful ransomware attack in a healthcare organisation and the operational, economic, regulatory, and reputational consequences that may follow. The analysis is informed by healthcare-specific evidence on cybersecurity controls, exposure conditions, and ransomware impacts, complemented by broader cyber-risk sources where sector-specific data were not available¹; Bayesian networks are well suited to this problem because they support reasoning under uncertainty in settings characterised by interdependence, incomplete data, and multi-causal risk. In this case, attack success depends on the interaction between multiple exposure pathways, defensive controls, and mitigation factors, while the consequences unfold across several interconnected dimensions. This framework therefore provides a transparent and interpretable basis for representing these dependencies and supporting scenario-based analysis.

1.3 Modelling Strategy

The model follows a Trigger–Control–Event–Mitigant–Consequence structure. Exposure pathways, namely *Third Parties Compromised*, *Vulnerability Exposure*, *Identity Exposure*, and *Phishing Exposure*, are used to determine the likelihood of *Initial Access*, while defensive measures such as *Network Segmentation*, *Patch Management*, *SIEM*, and *Cybersecurity Training and Awareness* are combined into a *Countermeasures* node. These two components jointly determine the core event of the model, the *Successful Ransomware Attack*. A set of mitigating factors, namely *Backup Presence*, *Ransom Paid*, *Full Data Encryption*, and *Security Automation*, is then used to capture how post-incident conditions may affect the severity and development of the consequences. The consequence layer includes *Recovery Cost*, *Operational Disruption Duration*, *Operational Disruption Cost*, *Data Leak*, *Regulatory Impact*, and *Reputational Impact*.

2 Model

In this chapter we explain how variables are interconnected and what is the reasoning behind them (2.1). Then, we present the assumptions underlying our model (2.2). Finally, we identify the weaknesses (2.3).

2.1 Model’s core

The structure of the model is organised around a central event, *Successful Ransomware Attack*, which represents the main outcome of interest. The model is built around four main components: trigger variables, countermeasures, mitigation variables, and consequence nodes. This structure allows the network to represent both the conditions leading to a ransomware attack and the effects that follow from it.

Triggers: All trigger variables are connected to the main event through the intermediate node *Initial Access*. This node represents whether an attacker is able to obtain a foothold within the organisation. It is modelled using a NoisyOR structure, where each trigger variable contributes as an independent causal pathway to initial access. In addition, a non-zero leak probability is included to account for alternative access mechanisms that are not explicitly

¹Detailed sources and node parameterisations are reported in Appendix A.

modeled. This formulation allows the model to capture multiple concurrent attack vectors while preserving a compact representation.

Countermeasures: Defensive controls are linked to the main event through the intermediate node *Countermeasures*. This node aggregates the effect of individual security controls and represents the overall level of defensive capacity. Its conditional probability table is constructed so as to combine the presence of multiple controls, effectively increasing the level of protection as more countermeasures are active. This approach allows the model to reflect the cumulative effect of defensive measures without modelling each interaction separately.

Main Event: The *Successful Ransomware Attack* node depends jointly on *Initial Access* and *Countermeasures*, capturing the idea that attack success requires both a successful entry point and insufficient defensive protection.

Mitigations: Mitigation variables are connected to the consequence layer, influencing both intermediate and final outcomes. These variables do not affect the occurrence of the main event but instead modify the severity and development of its consequences, reflecting the organization’s capacity to respond to and contain the impact of a ransomware attack.

Consequences: Following the occurrence of the main event, the model propagates its effects through a set of intermediate consequence nodes, namely *Data Leak*, *Recovery Cost*, and *Operational Disruption Duration*. These nodes represent the immediate outcomes of a successful attack and serve as inputs for downstream consequences. In particular, *Data Leak* is further connected to *Reputational Impact* and *Regulatory Impact*, reflecting the role of data exposure in driving both reputational damage and regulatory consequences. *Operational Disruption Duration*, instead, is directly linked to *Operational Disruption Cost* through a deterministic relationship.

2.2 Assumptions

1. Transferability of cross-sector estimates and interpretation of priors

We assume that some cross-sector estimates can be used as baseline priors for healthcare when equally clear healthcare-specific data are unavailable, as in the case of *Third Parties Compromised*, *Identity Exposure*, *Phishing Exposure*, and *Security Automation*.

In addition, the probabilities used in the model are interpreted as modelling priors rather than exact annual incidence rates or precise forecasts, since they are derived from heterogeneous empirical sources, including surveys, breach reports, and sectoral studies.

2. Use of proxies for indirectly observed nodes

We assume that certain variables that are not directly observable can be represented through measurable proxies. In particular, *Identity Exposure* is proxied by identity-related incidents relevant to initial access. Similarly, *Backup Presence* is proxied by the use of multiple backup approaches, and *Patch Management* is proxied by the routine patching of medical technology.

3. Calibration of the Initial Access NoisyOR

We assume that the four trigger nodes act as distinct causal pathways and can be represented using a NoisyOR structure, although some interaction may exist in practice. The NoisyOR parameters are calibrated based on the observed frequency of initial access vectors, and a residual probability of 0.03 is introduced to account for additional initial access pathways not explicitly modelled. This residual probability is intentionally kept small and conservative, reflecting the assumption that other attack pathways may exist but their aggregate contribution remains limited relative to the main exposure vectors included in the model. These frequencies are treated as approximate indicators of causal contribution rather than as exact causal probabilities.

4. Structure of attack success

We assume that a successful ransomware attack cannot occur without *Initial Access*. Once access is obtained and countermeasures are insufficient, the attack leads to operational disruption and other direct consequences in the model, including data leakage and recovery cost. *Countermeasures* are modelled additively, assuming equal contribution, monotonic reduction of risk, and independence between controls. Conditional probabilities are specified as reasoned modelling choices rather than empirical values.

5. Use of ransom payment rate as a prior

We assume that the Sophos figure indicating a 36% ransom payment rate can be used as a prior probability for the *Ransom Paid* node. Since this figure is derived from organisations that have already experienced

a ransomware attack, *Ransom Paid* is interpreted as a possible mitigation measure considered only in the presence of a ransomware attack, rather than as a probability applicable to the entire population of healthcare organisations.

6. Effect of ransom payment on downstream variables

We assume that ransom payment acts as a mitigation mechanism in the absence of other effective controls. Within the model, it is assumed to prevent data leakage, reduce operational disruption duration, and increase total recovery cost by adding the ransom payment to the baseline cost of a successful attack. This should be interpreted as a modelling simplification rather than as a claim that ransom payment reliably prevents disclosure or accelerates recovery in practice.

7. Construction of Recovery Cost

We assume that *Recovery Cost* is a constructed variable. It takes value 0 when no attack occurs, 1.02 million USD for a successful attack without ransom payment, and 1.17 million USD when the ransom is paid, approximating the sum of recovery cost and ransom payment.

8. Structure of Operational Disruption Duration

We assume that no disruption occurs if the attack is unsuccessful (0 days). If successful, ransom payment or backups reduce disruption to 1 day; otherwise, duration depends on *Security Automation*, which shifts the distribution toward shorter recovery times.

9. Linearity of downtime cost

We assume that the economic cost of operational disruption increases proportionally with downtime, using a constant average cost of 1.9 million USD per day. As a result, *Operational Disruption Cost* is directly derived from *Operational Disruption Duration*, implying a constant cost for each additional day of disruption.

10. Interpretation and mitigation role of Full Data Encryption

We assume that the 38% of healthcare organisations reporting comprehensive enterprise-wide encryption of data at rest can be represented as *Full Data Encryption = Yes*, while the remaining 62% are represented as *Full Data Encryption = No*.

11. Mapping of Reputational Impact and Regulatory Impact

We assume that *Reputational Impact* and *Regulatory Impact* depend on *Data Leak* and are mitigated by *Full Data Encryption*. When no leak occurs, impacts remain low; when a leak occurs, impacts increase but are reduced if data are encrypted since relevant regulations such as GDPR strongly encourage the use of encryption.

2.3 Weaknesses

1. Limited scope and reliance on external data

To keep the model compact and interpretable, only a subset of relevant ransomware risk factors and consequences is explicitly represented. Important aspects such as privilege escalation, lateral movement, incident response maturity, cyber insurance, hospital size and complexity, the type and volume of compromised data, and patient-safety consequences, including delayed care, cancelled procedures, ambulance diversion, and reduced clinical capacity, are therefore outside the model scope, although they may affect both the likelihood and impact of attacks.

In addition, since several nodes rely on cross-sector data or proxy measures rather than healthcare-specific evidence, the estimated probabilities may be subject to bias or distortion and should therefore be interpreted as baseline approximations rather than precise measures of healthcare-sector risk.

2. Imperfect representation of variables

Several variables are represented through proxies or simplified mappings that may not fully capture the underlying phenomena. For example, *Identity Exposure* is inferred from identity-related incidents, which may underestimate exposure if attacks go undetected, while *Backup Presence* reflects the existence of backups rather than their effectiveness.

Similarly, *Patch Management*, *Network Segmentation*, *SIEM*, *Cybersecurity Training and Awareness*, and *Full Data Encryption* describe the presence of general practices rather than their real-world implementation quality, potentially introducing measurement error and bias.

3. Simplified structural modelling

The model relies on simplified structural assumptions that may limit its ability to capture real-world attack dynamics. *Countermeasures* are aggregated additively, assuming equal contribution, independence, and monotonic risk reduction, which may overlook interactions or differences in control effectiveness. *Successful Ransomware Attack* is defined without modelling intermediate stages, while the NoisyOR structure for *Initial Access* treats attack vectors as partially independent and includes a residual probability for unmodelled pathways. Some variables may also be correlated or overlapping, such as phishing and identity exposure, third-party compromise and credential theft, or vulnerability exposure and patch management. These choices improve interpretability but may oversimplify attack processes, introduce partial double counting, and affect probability propagation.

4. Simplified modelling of consequences

Several consequence nodes rely on simplified representations. *Recovery Cost* combines different statistics, *Operational Disruption Duration* is based on recovery-time evidence, and *Operational Disruption Cost* assumes a linear relationship with downtime. These assumptions improve tractability but may reduce realism, especially if costs evolve non-linearly. More broadly, the model tends to produce moderate rather than extreme outcomes, as probabilities remain bounded. In particular, *Data Leak* is constrained by its specification, and *Full Data Encryption* may underestimate reputational and regulatory impacts, as the model assumes that encrypted data are effectively protected. This simplification may lead to an underestimation or misrepresentation of the mitigating effect of encryption on downstream impacts. Finally, ransom payment may be modelled as more effective than it is in practice, since payment does not guarantee data deletion, non-disclosure, or faster recovery.

5. Absence of a time dimension

The model does not include an explicit time dimension. All outcomes are represented as static probabilities, meaning that dynamic processes such as attack evolution, delayed recovery, or the timing of disruption and response cannot be captured dynamically.

3 Scenarios

In this chapter we present some scenarios and leverage our model to solve them. For clarity, we present only the answers of the scenarios here, nodes setting and full results of the model can be found in Appendix B.

3.1 Scenario 1: “Worst and Best Case for a Healthcare Organisation”

Following the growing number of ransomware attacks affecting hospitals and healthcare providers, this scenario analyses the two most extreme plausible situations for an organisation in our model. In the worst case, the organisation is exposed through all the main attack pathways and lacks both preventive controls and resilience mechanisms. In the best case, exposure is absent and all the main defensive and recovery measures are in place. The purpose of this scenario is to show how strongly the overall security posture of the organisation can influence both the success of the attack and the severity of its consequences.

Q1: How does the probability of a *Successful Ransomware Attack* vary across the two configurations relative to the baseline?

A1: The probability of a *Successful Ransomware Attack* increases from a baseline of 9% to 50.49% in the worst case, while in the best case it decreases significantly from a baseline of 9% to 0.15%.

Q2: Which consequence shows the largest change between the worst-case and best-case configurations?

A2: The largest change is observed in *Regulatory Impact*. In the worst-case configuration, most of the probability mass is concentrated in the Medium and High states, whereas in the best-case configuration it shifts almost entirely to Low. A similarly strong improvement is also visible in the operational dimension, where most of the probability mass moves toward zero days of disruption, leading to a substantial reduction in *Operational Disruption Cost*.

Considerations: The results suggest that the strongest effect of the best-case configuration comes from reducing the probability of attack propagation through the central node, rather than from improving each consequence separately. Across configurations, outcomes diverge significantly: in the best case, a sharp reduction in attack probability largely suppresses downstream impacts, whereas in the worst case, the higher likelihood of attack amplifies these consequences. This effect is especially visible on the operational side, since disruption duration and cost depend directly on attack success and the availability of recovery capabilities. Since *Ransom Paid* is fixed at No in both

configurations, the difference between the two cases is primarily explained by the combination of exposure conditions, preventive controls, and resilience measures such as backups and security automation.

3.2 Scenario 2: “Prevention vs Resilience”

This scenario compares two alternative cybersecurity strategies within the model. In the first case, the organisation prioritises preventive controls in order to reduce the likelihood of a successful ransomware attack. In the second case, preventive capacity is weaker, but resilience measures are stronger, allowing the organisation to better contain the consequences once the attack occurs. The purpose of this scenario is to assess whether it is more effective to reduce the probability of attack success or to mitigate its downstream impacts.

Q1: Which strategy is more effective at reducing the probability of a *Successful Ransomware Attack*?

A1: The prevention-focused strategy is more effective at reducing the probability of a *Successful Ransomware Attack*, lowering it to 2.66% compared with 50.49% in the resilience-focused configuration.

Q2: Which strategy is more effective overall at reducing the final consequences of the incident?

A2: The prevention-focused strategy is more effective at reducing the final consequences, as it significantly lowers the probability of a *Successful Ransomware Attack*, thereby limiting the propagation of downstream impacts across the network.

Considerations: The results suggest that prevention and resilience act on different parts of the network and therefore improve different aspects of cyber risk. The prevention-focused configuration is much more effective at lowering the probability of a *Successful Ransomware Attack*, since stronger countermeasures act directly on the central event. As a result, it is also more effective overall at reducing the final consequences of the incident, because the lower probability of attack success suppresses most downstream impacts across the network. By contrast, the resilience-focused configuration does not prevent the attack as effectively, but it still helps limit the severity of some consequences once the attack occurs, particularly *Regulatory Impact* shifts toward lower states. Overall, the model shows that prevention is the more effective strategy for reducing both attack success and aggregate impact, while resilience remains valuable for containing part of the damage after compromise.

3.3 Scenario 3: “Paying Under Pressure”

After a successful ransomware attack, a healthcare organisation decides to pay the ransom to restore operations and reduce the disruption caused by the incident. Since the attack has already succeeded, the organisation can no longer prevent the event itself and instead relies on payment as a post-incident response. The purpose of this scenario is to assess how far ransom payment can mitigate the final consequences of the attack.

Q1: What is the expected *Operational Disruption Duration* and *Operational Disruption Cost* when a *Successful Ransomware Attack* occurs and the ransom is paid?

A1: The expected *Operational Disruption Duration* is 1 day, and the corresponding *Operational Disruption Cost* is USD 1.9 million.

Q2: What is the total *Recovery Cost*?

A2: The estimated *Recovery Cost* is USD 1.17 million.

Q3: What are the impacts in terms of *Data Leak*, *Reputational Impact*, and *Regulatory Impact*?

A3: The model predicts no *Data Leak*, resulting in *Reputational Impact* = 100% Low, while *Regulatory Impact* = 100% Medium.

Considerations: The model suggests that ransom payment mainly acts as a post-incident containment measure rather than a true solution to the attack. In this scenario, paying the ransom immediately shifts the outcome toward a short disruption and, according to the model assumptions, prevents data leakage, which keeps reputational impact low as the data is quickly recovered. However, this does not remove the economic burden of the incident, since *Recovery Cost* remains high precisely because the attack succeeds and the ransom is added to the restoration cost. *Regulatory Impact* also remains medium, showing that payment may limit some consequences, but it does not erase the fact that a serious cyber incident still occurred.

3.4 Scenario 4: “Aftermath Analysis”

Given the observation of severe consequences consistent with a ransomware incident, a healthcare organisation seeks to understand what most likely happened during the crisis. The observed outcomes include maximum reputational and

regulatory impact, very long operational disruption, and substantial recovery cost. Since only the final consequences are observed, the network is used in reverse to infer the most plausible upstream conditions that could have generated them. The purpose of this scenario is therefore to identify the combination of exposure conditions, control weaknesses, and missing mitigation measures that is most consistent with these extreme outcomes.

Q1: Based on the observed outcomes, what type of attack scenario could have plausibly resulted in these consequences?

A1: The model suggests that the observed extreme outcomes are most consistent with a scenario characterised by very high exposure, certain *Initial Access*, and a fully successful ransomware attack. *Vulnerability Exposure*, *Identity Exposure*, and *Phishing Exposure* are all inferred at high levels, while *Initial Access* and *Successful Ransomware Attack* are both driven to 100%. At the same time, the model indicates a weakened defensive posture, particularly through the deterioration of *Patch Management*, and an almost complete absence of mitigation capacity.

Considerations: This scenario shows that the most severe consequences in the network do not arise from a single missing control, but from the combination of strong exposure, successful attack execution, and limited capacity to mitigate downstream effects. The results do not suggest that all preventive controls are entirely absent; rather, they point to a weakened overall control posture, with some controls remaining partially present but insufficient to stop the incident from escalating. The scenario also highlights the importance of internal consistency in the model: *Recovery Cost* is fixed at USD 1.02 million rather than USD 1.17 million, because the higher value would imply ransom payment, which would be inconsistent with the extreme downstream consequences observed here.

4 Conclusions

This work aimed to explore how exposure conditions, defensive controls, mitigation measures, and consequence variables influence the ransomware risk profile of a healthcare organisation. By leveraging Bayesian networks, we created a probabilistic model able to represent both the likelihood of a successful ransomware attack and the operational, economic, regulatory, and reputational consequences that may follow. The Trigger–Control–Event–Mitigant–Consequence structure provided a transparent framework for linking initial access pathways, preventive controls, post-incident mitigation, and downstream impacts.

From the analysis of the four defined scenarios, the following key considerations are derived:

- **Prevention has the strongest effect on overall risk**

Across the scenarios, the probability of a *Successful Ransomware Attack* is mainly shaped by *Initial Access* and *Countermeasures*. The comparison between worst-case, best-case, and prevention-focused configurations shows that reducing exposure and strengthening controls sharply lowers attack success and limits the propagation of downstream consequences.

- **Mitigation reduces severity but does not remove the incident**

Backups, security automation, full data encryption, and ransom payment can reduce specific consequences once an attack has occurred, especially disruption duration, data leakage, and regulatory or reputational impacts. However, they do not prevent the central event itself and may still leave substantial recovery costs.

- **Severe outcomes arise from combined weaknesses**

The aftermath scenario shows that the most extreme consequences are consistent with high exposure, successful initial access, insufficient defensive capacity, and limited mitigation. This confirms that ransomware risk should be interpreted as a multi-causal process rather than the result of a single missing control.

Despite these insights, the model remains subject to important limitations. It simplifies real-world attack dynamics, relies on several assumptions, and uses cross-sector data or proxy measures when healthcare-specific evidence is unavailable. Some relationships are deterministic or simplified, and the absence of an explicit time dimension means that attack evolution and recovery cannot be captured dynamically. Therefore, the results should be interpreted as scenario-based probabilistic insights rather than precise forecasts.

Overall, the model provides a useful sandbox for comparing ransomware risk configurations in healthcare. The results suggest that prevention is the most effective strategy for reducing aggregate risk, while resilience and mitigation measures remain important for limiting damage when prevention fails.

Appendix A. Bayesian Network Model Details

Legend

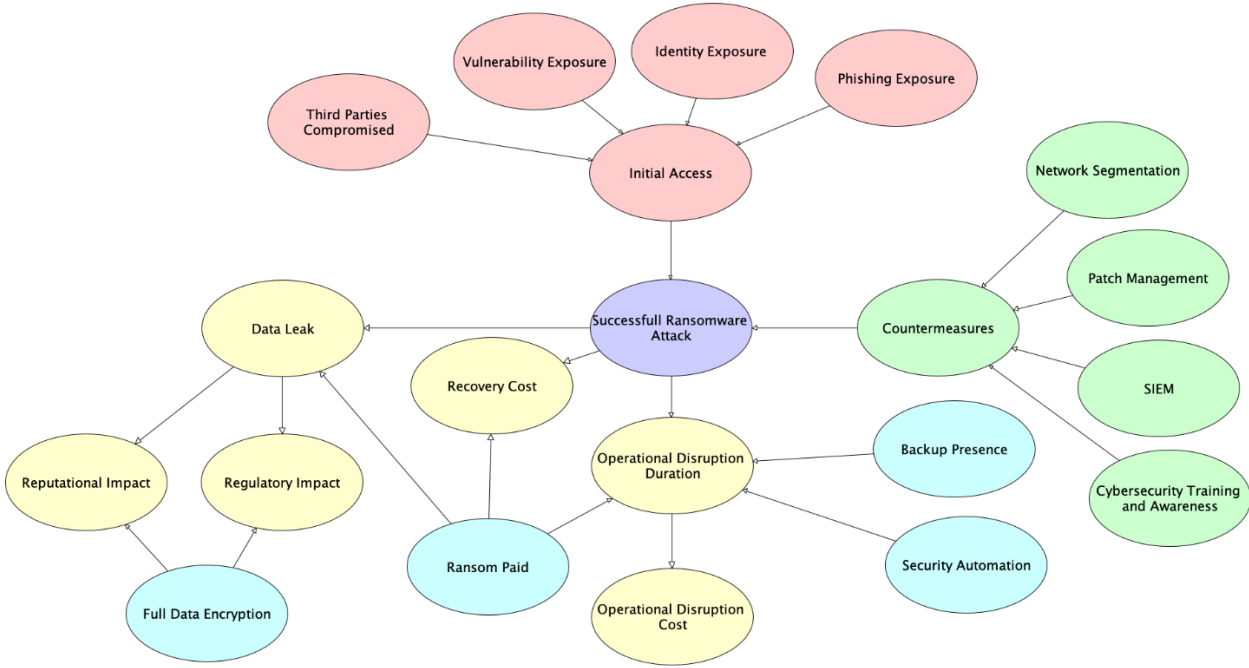


Figure A.1: Bayesian Network

A.1 Third Parties Compromised (TPC)

- **Type:** Boolean (True/False)
- **Probability:** Prior Probability Table:
 - True: 0.0424
 - False: 0.9576
- **Description:** The node represents whether the organisation is affected by a third-party or supply-chain compromise. It was modelled as a Boolean node because it captures the presence or absence of this condition, not its severity. The prior was derived from the 2024 ITRC Data Breach Report by dividing 134 directly impacted organisations by 3,158 total data compromises. Indirectly impacted entities were excluded to avoid double counting, since they reflect downstream effects of the same compromise events rather than independent attacks. Although the source is cross-sector, this value was used as a baseline prior for healthcare because third-party compromise in 2024 was strongly influenced by the Change Healthcare incident. This may still understate systemic exposure in healthcare.
- **Sources:** [1]

A.2 Vulnerability Exposure / KEVs Present (VE)

- **Type:** Boolean (True/False)
- **Probability:** Prior Probability Table:
 - True: 0.99
 - False: 0.01
- **Description:** The node represents whether the organisation is exposed to known exploitable vulnerabilities. It was modelled as a Boolean node because the available evidence supports a presence-versus-absence interpretation more clearly than a graded scale of severity. The prior was based on healthcare-specific evidence reporting that 99% of hospitals and healthcare delivery organisations in the dataset were managing IoMT devices with known exploited vulnerabilities (KEVs). This node is intended to capture whether the organisation is exposed to vulnerabilities that are already known to be exploited in the wild and are therefore especially relevant to ransomware risk.
- **Sources:** [2]

A.3 Identity Exposure (IE)

- **Type:** Boolean (True/False)
- **Probability:** Prior Probability Table:
 - True: 0.91
 - False: 0.09
- **Description:** The node represents whether the organisation is exposed to compromised identity assets that may facilitate unauthorised access, including exposed credentials, session cookies, tokens and related identity data. It was modelled as a Boolean node because it captures the presence or absence of this condition, rather than its severity. The prior was set using the finding that 91% of organisations reported an identity-related incident in the past year. This measure does not directly observe identity exposure itself, but it was used as a reasonable proxy because the same source links exposed identity data to follow-on attacks, including ransomware.
- **Sources:** [3]

A.4 Phishing Exposure (PE)

- **Type:** Boolean (True/False)
- **Probability:** Prior Probability Table:
 - True: 0.75
 - False: 0.25
- **Description:** The node represents whether the organisation is exposed to phishing-based social engineering attempts. It was modelled as a Boolean node because it captures the presence or absence of this condition, rather than its severity. The prior was derived from 2021 State of the Phish Report, which states that more than 75% of organisations faced broad-based phishing attacks. Although the source is cross-sector, this value was used as a baseline prior for healthcare because phishing is a major initial-access vector and the HHS HC3 white paper identifies it as the most common attack affecting healthcare organisations.
- **Sources:** [4], [5]

A.5 Initial Access (IA)

- **Type:** Boolean (True/False)
- **Probability:** NoisyOR structure with four parent nodes:
 - Third Parties Compromised $\rightarrow$ Initial Access = 0.10
 - Vulnerability Exposure / KEVs Present $\rightarrow$ Initial Access = 0.21
 - Identity Exposure Present $\rightarrow$ Initial Access = 0.21
 - Phishing Exposure $\rightarrow$ Initial Access = 0.14
 - Leak = 0.03
- **Description:** The node represents whether an attacker succeeds in obtaining an initial foothold in the organisation. It was modelled as a Boolean node using a NoisyOR structure, since the selected trigger nodes represent distinct access pathways that may independently lead to compromise. The NoisyOR strengths were calibrated using the empirical frequency with which these vectors appear as initial infection paths in the available sources. A small non-zero leak term was introduced to account for additional initial access routes not explicitly included in the model.
- **Sources:** [5], [6]

A.6 Network Segmentation (NS)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.883
 - No: 0.117
- **Description:** The node represents whether some form of network segmentation is implemented within the organisation. It was modelled as a Boolean prior node because the available evidence supports the presence of segmentation as an organisational practice, but not a sufficiently precise maturity scale. The prior was set using the finding that 88.3% of organisations reported implementing some form of network segmentation. This node therefore captures the existence of the control rather than its completeness or effectiveness.
- **Sources:** [7]

A.7 Patch Management (PM)

- **Type:** Boolean (Good/Poor)
- **Probability:** Prior Probability Table:
 - Good: 0.6018
 - Poor: 0.3982
- **Description:** The node represents whether patching is performed as an effective organisational control. It was modelled as a Boolean prior node because it captures the presence or absence of routine patching, rather than its degree of maturity. The prior was derived from the HHS Hospital Cyber Resiliency Initiative, which reports that 60.18% of hospitals routinely patch medical technology when a patch is released by the manufacturer. This value was used as a healthcare-specific prior and as a proxy for patch management effectiveness in the model.
- **Sources:** [7]

A.8 SIEM/Security Monitoring (SIEM)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.943
 - No: 0.057
- **Description:** The node represents whether the organisation has SIEM-based monitoring or equivalent security monitoring capability in place. It was modelled as a Boolean prior node because the underlying evidence supports whether this capability is deployed, but not how well it is tuned, staffed, or operationally mature. The prior was derived from Figure 13 of the HHS Hospital Cyber Resiliency Initiative, which reports an adoption level of 94.3% for Security Information and Event Management among participating hospitals. This value was used as a healthcare-specific prior for the model.
- **Sources:** [7]

A.9 Cybersecurity Training and Awareness (CTA)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.86
 - No: 0.14
- **Description:** The node represents whether users are informed and trained regarding cybersecurity-related duties and responsibilities. It was modelled as a Boolean prior node because the available evidence supports the existence of training activity, rather than a more granular measure of user competence or programme effectiveness. The prior was set using the finding that 86% of hospitals reported that their users are informed and trained on their cybersecurity-related duties and responsibilities. This node therefore captures the presence of training and awareness activity within the organisation, not its quality or effectiveness.
- **Sources:** [7]

A.10 Countermeasures (CM)

- **Type:** Ranked, 5 states (Very Low, Low, Medium, High, Very High)
- **Probability:** Conditional Probability Table
 - Very Low: no active countermeasures
 - Low: one active countermeasure
 - Medium: two active countermeasures
 - High: three active countermeasures
 - Very High: four active countermeasures

Patch Management	Poor								Good							
SIEM	No				Yes				No				Yes			
Network Segmentation	No		Yes		No		Yes		No		Yes		No		Yes	
Cybersecurity Training and Awareness	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes
Very Low	1	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
Low	0	1	1	0	1	0	0	0	1	0	0	0	0	0	0	0
Medium	0	0	0	1	0	1	1	0	0	1	1	0	1	0	0	0
High	0	0	0	0	0	0	0	1	0	0	0	1	0	1	1	0
Very High	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	1

Table A.1: Conditional Probability Table for Countermeasures

- **Description:** The node represents the overall level of defensive coverage of the organisation. It was modelled as a ranked node in order to aggregate the four control variables into a single ordered measure of defensive posture. The parameterisation is based on the number of active controls and assumes that each countermeasure contributes equally to the overall level of protection. This structure was adopted to keep the model compact and interpretable while preserving a monotonic increase in defensive coverage from Very Low to Very High.

A.11 Successful Ransomware Attack (SRA)

- **Type:** Boolean (True/False)
- **Probability:** Conditional Probability Table

Initial Access Countermeasures	False					True				
	Very Low	Low	Medium	High	Very High	Very Low	Low	Medium	High	Very High
False	1	1	1	1	1	0.05	0.25	0.5	0.75	0.95
True	0	0	0	0	0	0.95	0.75	0.5	0.25	0.05

Table A.2: Conditional Probability Table for Successful Ransomware Attack

- **Description:** The node represents whether the ransomware attack succeeds, meaning that the attacker has obtained initial access and the organisation's defensive posture is not sufficient to prevent attack progression. It was modelled as a Boolean node with a manually specified conditional probability table in order to make the relationship between access, defensive strength, and ransomware success more transparent. In this model, the success of the attack refers specifically to the encryption of the organisation's data. The probability of success is therefore zero when initial access is absent and decreases monotonically as the level of Countermeasures increases.

A.12 Backup Presence (BP)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.42

– No: 0.58

- **Description:** The node represents whether the organisation has a backup strategy in place. It was modelled as a Boolean prior node because it captures the presence or absence of this mitigating condition, rather than its quality or maturity. The prior was derived from Becker’s Hospital Review, which reports that 42% of hospitals use multiple data backup approaches to ensure the availability of critical data in the event of IT outages or other emergencies. This measure was used as a prudent proxy for robust backup presence in the healthcare sector, even though it does not directly measure simple backup availability.
- **Sources:** [8]

A.13 Ransom Paid (RP)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.36
 - No: 0.64
- **Description:** The node represents whether the organisation pays the ransom during a ransomware incident. It was modelled as a Boolean node because it captures the presence or absence of the payment decision rather than the amount paid. The prior was set using the finding that 36% of healthcare organisations paid the ransom in 2025. Although this figure is observed among organisations already affected by ransomware rather than across the full population of healthcare organisations, it was used as a sector-specific empirical baseline for payment behaviour within ransomware cases. It remains useful because, in the model, ransom payment influences not only financial cost but also other downstream consequences. Therefore, Ransom Paid should be interpreted as a possible mitigation decision considered only in the presence of a ransomware attack, rather than as a probability applicable to all healthcare organisations regardless of attack occurrence.
- **Sources:** [9]

A.14 Full Data Encryption (FDE)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.38
 - No: 0.62
- **Description:** The node represents whether encryption for data at rest has been implemented comprehensively across the organisation. It was modelled as a Boolean node because it captures the presence or absence of full enterprise-wide encryption, rather than partial implementation. The prior was derived from the 2021 HIMSS Healthcare Cybersecurity Survey, which reports that 38% of respondents have implemented encryption for data at rest comprehensively across the enterprise, while the remaining 62% should be interpreted as the absence of full coverage rather than the complete absence of encryption.
- **Sources:** [10]

A.15 Security Automation (SA)

- **Type:** Boolean (Yes/No)
- **Probability:** Prior Probability Table:
 - Yes: 0.31
 - No: 0.69

- **Description:** The node represents whether the organisation makes extensive use of security artificial intelligence and automation as a mitigating capability. It was modelled as a Boolean prior node because the available evidence supports prevalence of adoption, rather than a more detailed maturity scale. The prior was set using the finding that 31% of organisations reported extensive use of security AI and automation. In the model, this node captures the presence of a mature AI-and-automation-enabled security capability rather than generic experimentation with AI tools, and its main role is mitigative rather than preventive, since it affects the likely duration of disruption once an event has occurred.

- **Sources:** [11]

A.16 Recovery Cost (RC)

- **Type:** Discrete Real
- **Probability:** Conditional Probability Table
 - If Successful Ransomware Attack = No, then Recovery Cost = 0.0
 - If Successful Ransomware Attack = Yes and Ransom Paid = No, then Recovery Cost = 1.02
 - If Successful Ransomware Attack = Yes and Ransom Paid = Yes, then Recovery Cost = 1.17

Successful Ransomware Attack	False		True	
	Ransom Paid	No	Yes	No
0.0	1	1	0	0
1.02	0	0	1	0
1.17	0	0	0	1

Table A.3: Conditional Probability Table for Recovery Cost

- **Description:** The node represents the direct financial recovery consequence of the incident. It was modelled as a discrete real node with three fixed outcomes in order to keep the cost logic transparent and directly linked to the ransomware event. If no successful ransomware attack occurs, the cost is set to 0. If the attack succeeds and no ransom is paid, the cost is set to 1.02 million USD, reflecting the reported mean recovery cost excluding ransom. If the attack succeeds and the ransom is paid, the cost is set to 1.17 million USD, obtained by adding the 1.02 million USD recovery cost to the 150,000 USD ransom payment benchmark used in the model.
- **Sources:** [9]

A.17 Data Leak (DL)

- **Type:** Boolean (True/False)
- **Probability:** Conditional Probability Table

Successful Ransomware Attack	False		True	
Ransom Paid	No	Yes	No	Yes
False	1	1	0.73	1
True	0	0	0.27	0

Table A.4: Conditional Probability Table for Data Leak

- **Description:** The node represents whether the successful ransomware attack also results in data exposure or exfiltration. It was modelled as a Boolean node with Successful Ransomware Attack and Ransom Paid as parent nodes. This structure reflects the logic of the model, in which data leakage is treated as a downstream consequence of a successful ransomware event, while ransom payment affects whether extortion is assumed to continue through disclosure. Accordingly, data leakage can occur only if the central ransomware event has been successful. When the attack is successful and no ransom is paid, the probability of Data Leak was set to 0.27, based on Sophos' healthcare-specific finding that 27% of healthcare providers that had data encrypted also experienced data exfiltration. In the model, when the ransom is paid, data leakage is assumed not to occur.
- **Sources:** [9]

A.18 Reputational Impact (RI)

- **Type:** Boolean (Low, High)
- **Probability:** Conditional Probability Table
 - If Data Leak = No, then Reputational Impact = Low
 - If Data Leak = Yes and Full Data Encryption = Yes, then Reputational Impact = Low
 - If Data Leak = Yes and Full Data Encryption = No, then Reputational Impact = High

Full Data Encryption	No		Yes	
Data Leak	False	True	False	True
Low	1	0	1	1
High	0	1	0	0

Table A.5: Conditional Probability Table for Reputational Impact

- **Description:** The node represents the reputational consequences of the incident. It was modelled as a Boolean consequence node with the customised states Low and High, because the purpose of the model is to distinguish between limited and severe reputational harm rather than to provide a more granular brand-damage scale. The node depends on Data Leak and Full Data Encryption. In the adopted structure, reputational impact remains low when no data leak occurs and becomes high only when data are leaked while full data encryption

is absent. If full data encryption is in place, reputational impact is kept low even when a leak occurs, based on the assumption that encrypted data are less immediately intelligible and therefore less damaging from a reputational perspective.

A.19 Regulatory Impact (RegI)

- **Type:** Ranked, 3 states (Low, Medium, High)
- **Probability:** Conditional Probability Table (Deterministic)
 - If Data Leak = No and Full Data Encryption = Yes, then Regulatory Impact = Low
 - If Data Leak = No and Full Data Encryption = No, then Regulatory Impact = Medium
 - If Data Leak = Yes and Full Data Encryption = Yes, then Regulatory Impact = Medium
 - If Data Leak = Yes and Full Data Encryption = No, then Regulatory Impact = High

Full Data Encryption	No		Yes	
Data Leak	False	True	False	True
Low	0	0	1	0
Medium	1	0	0	1
High	0	1	0	0

Table A.6: Conditional Probability Table for Regulatory Impact

- **Description:** The node represents the level of regulatory consequence associated with the incident. It was modelled as a ranked node with three states in order to distinguish between lower, intermediate, and higher levels of regulatory exposure. The node depends on Data Leak and Full Data Encryption and follows a simplified GDPR-inspired logic. In the adopted structure, regulatory impact is lowest when full data encryption is present and no data leak occurs, highest when data are leaked while full data encryption is absent, and intermediate in the two mixed cases. This formulation was chosen because, in a healthcare setting, regulatory exposure depends not only on whether an attack occurs, but also on whether sensitive data are actually exposed and whether strong data protection was already in place.
- **Sources:** [12]

A.20 Operational Disruption Duration (ODD)

- **Type:** Discrete Real
- **Probability:** Conditional Probability Table
 - If Successful Ransomware Attack = No, then Operational Disruption Duration = 0 days
 - If Successful Ransomware Attack = Yes and Ransom Paid = Yes, then Operational Disruption Duration = 1 day
 - If Successful Ransomware Attack = Yes and Backup Presence = Yes, then Operational Disruption Duration = 1 day
 - If Successful Ransomware Attack = Yes, Ransom Paid = No, Backup Presence = No, and Security Automation = No, then: 0 days: 0, 1 day: 0.16, 7 days: 0.37, 30 days: 0.28, 180 days: 0.19

- If Successful Ransomware Attack = Yes, Ransom Paid = No, Backup Presence = No, and Security Automation = Yes, then: 0 days: 0, 1 day: 0.26, 7 days: 0.50, 30 days: 0.20, 180 days: 0.04

Successful Ransomware Attack	False								True							
Ransom Paid	No				Yes				No				Yes			
Backup Presence	No		Yes		No		Yes		No		Yes		No		Yes	
Security Automation	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes	No	Yes
0 (days)	1	1	1	1	1	1	1	1	0	0	0	0	0	0	0	0
1 (day)	0	0	0	0	0	0	0	0	0.16	0.26	1	1	1	1	1	1
7 (days)	0	0	0	0	0	0	0	0	0.37	0.50	0	0	0	0	0	0
30 (days)	0	0	0	0	0	0	0	0	0.28	0.20	0	0	0	0	0	0
180 (days)	0	0	0	0	0	0	0	0	0.19	0.04	0	0	0	0	0	0

Table A.7: Conditional Probability Table for Operational Disruption Duration

- **Description:** The node represents the duration of operational disruption caused by the incident. It was modelled as a discrete real node with five states: 0, 1, 7, 30, and 180 days. The CPT was defined so that disruption is absent when the ransomware attack is unsuccessful, while a successful attack leads to a 1-day disruption if recovery is facilitated by ransom payment or backup presence. When the ransomware attack is successful and neither payment nor backups are available, disruption duration depends on Security Automation, which is assumed to shift the distribution toward shorter recovery times. The calibrated probabilities were informed by Sophos’ healthcare recovery-time evidence and IBM’s findings on faster breach identification and containment associated with extensive security AI and automation. It allows the model to express the idea that disruption duration depends not only on whether the attack succeeds, but also on whether the organisation has recovery-enabling or mitigating factors available after the event.
- **Sources:** [9], [11]

A.21 Operational Disruption Cost (ODC)

- **Type:** Ranked, 5 states (0, 1.9, 13.3, 57, 342)
- **Probability:** Conditional Probability Table
 - If Operational Disruption Duration = 0 days, then Operational Disruption Cost = 0.0
 - If Operational Disruption Duration = 1 day, then Operational Disruption Cost = 1.9
 - If Operational Disruption Duration = 7 days, then Operational Disruption Cost = 13.3
 - If Operational Disruption Duration = 30 days, then Operational Disruption Cost = 57.0
 - If Operational Disruption Duration = 180 days, then Operational Disruption Cost = 342.0

Operational Disruption Cost (USD)	Operational Disruption Duration (days)				
	0	1	7	30	180
0	1	0	0	0	0
1.9	0	1	0	0	0
13.3	0	0	1	0	0
57	0	0	0	1	0
342	0	0	0	0	1

Table A.8: Conditional Probability Table for Operational Disruption Cost

- **Description:** The node represents the economic cost associated with operational disruption. It was modelled as a ranked consequence node with ordered monetary states derived directly from Operational Disruption Duration, so that longer disruption periods correspond to higher cost levels. The mapping assumes a constant daily downtime cost of USD 1.9 million, based on Becker's Hospital Review, which reports this figure from a Comparitech analysis of ransomware incidents affecting healthcare organisations. This node was included to translate downtime into an ordered financial consequence within the network, which is especially important in healthcare, where interruption of operations can generate substantial losses.
- **Sources:** [8]

Appendix B. Scenario Results

Baseline scenario:

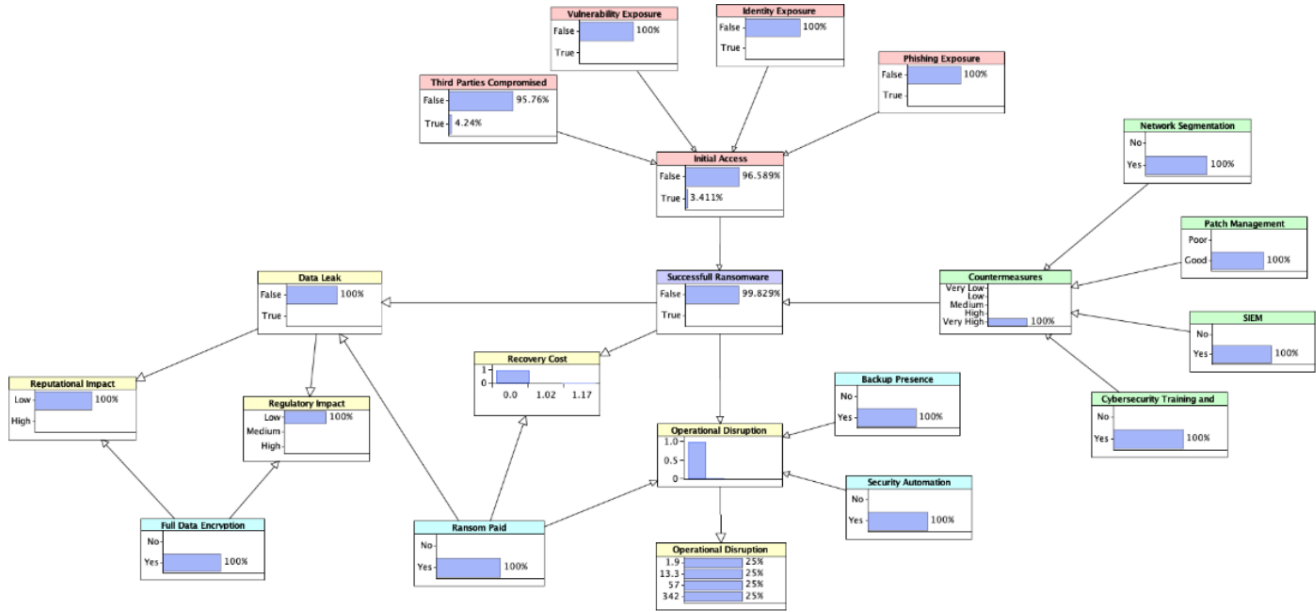


Figure B.2: Baseline scenario of the Bayesian Network

B.1 Scenario 1- Results

Node Case Settings:

Variable	Worst Case	Best Case
Third Party Compromise	YES	NO
Vulnerability Exposure	YES	NO
Identity Exposure	YES	NO
Phishing Exposure	YES	NO
Network Segmentation	NO	YES
Patch Management	NO	YES
SIEM	NO	YES
Cybersecurity Training & Awareness	NO	YES
Backup Presence	NO	YES
Full Data Encryption	NO	YES
Security Automation	NO	YES
Ransom Paid	NO	NO

Table B.9: Node case settings for Scenario1

Q1:

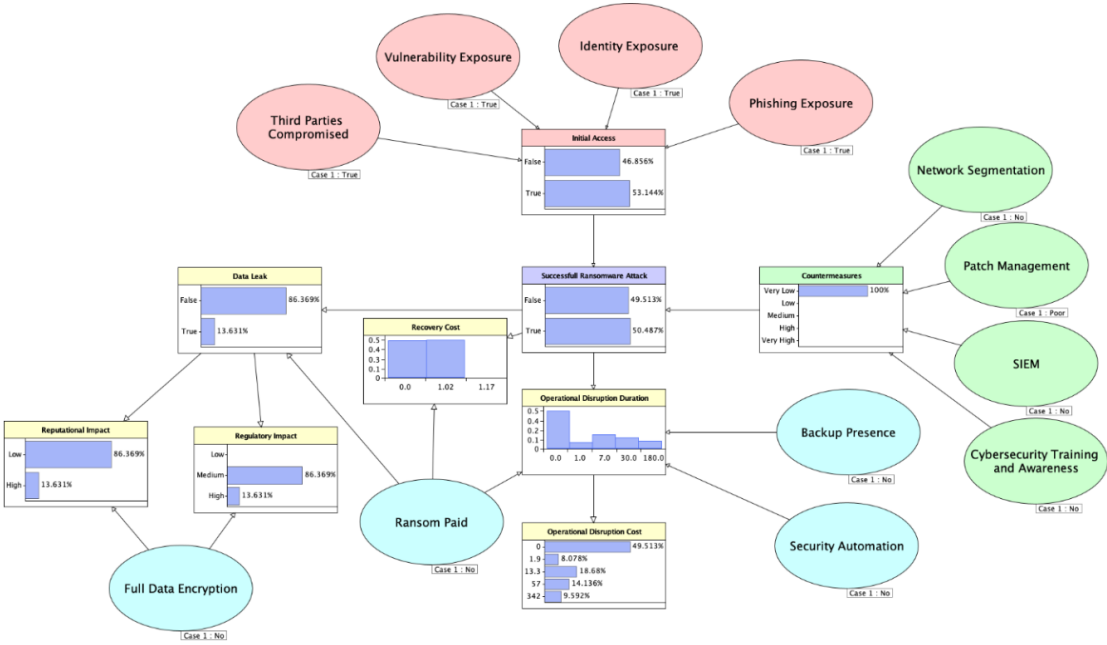


Figure B.3: Results of Scenario 1 - Worst-case configuration

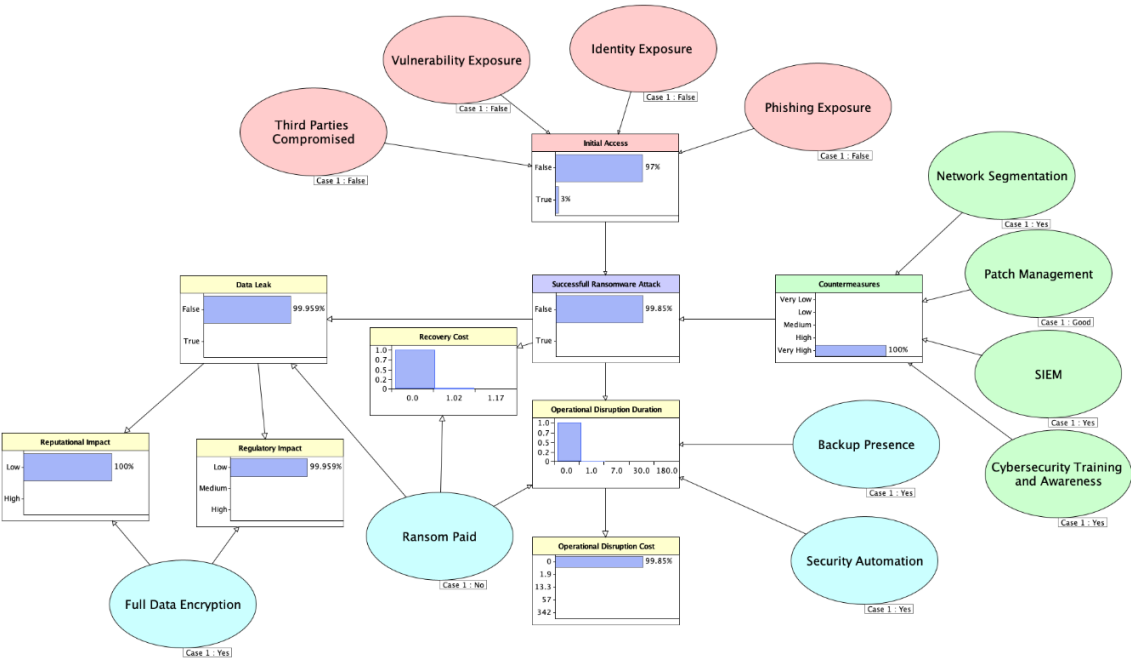


Figure B.4: Result of Scenario 1 - Best-case configuration

Q2:

	State	Worst Case	Best Case	Difference (Best - Worst)
Data Leak	False	86.37%	99.97%	13.60%
	True	13.63%	0.04%	-13.59%
Recovery Cost (USD million)	0	49.51%	99.85%	50.34%
	1.02	50.49%	0.15%	-50.34%
	1.17	0%	0%	0%
Reputational Impact	Low	86.37%	100%	13.63%
	High	13.63%	0%	-13.63%
Regulatory Impact	Low	0%	99.96%	99.96%
	Medium	86.37%	0.04%	-86.33%
	High	13.63%	0%	-13.63%
Operational Disruption Duration (Days)	0	49.51%	99.85%	50.34%
	1	8.08%	0.15%	-7.93%
	7	18.68%	0%	-18.68%
	30	14.14%	0%	-14.14%
	180	9.59%	0%	-9.59%
Operational Disruption Cost (USD million)	0	49.51%	99.85%	50.34%
	1.9	8.08%	0.15%	-7.93%
	13.3	18.68%	0%	-18.68%
	57	14.14%	0%	-14.14%
	342	9.59%	0%	-9.59%

Table B.10: Result of Scenario 1 – Comparisons' consequences

B.2 Scenario 2- Results

Node Case Settings:

Variable	Prevention-Focused Organization	Resilience-Focused Organization
Third Party Compromise	YES	YES
Vulnerability Exposure	YES	YES
Identity Exposure	YES	YES
Phishing Exposure	YES	YES
Network Segmentation	YES	NO
Patch Management	YES	NO
SIEM	YES	NO
Cybersecurity Training & Awareness	YES	NO
Backup Presence	NO	YES
Full Data Encryption	NO	YES
Security Automation	NO	YES
Ransom Paid	NO	NO

Table B.11: Node case settings for Scenario 2

Q1:

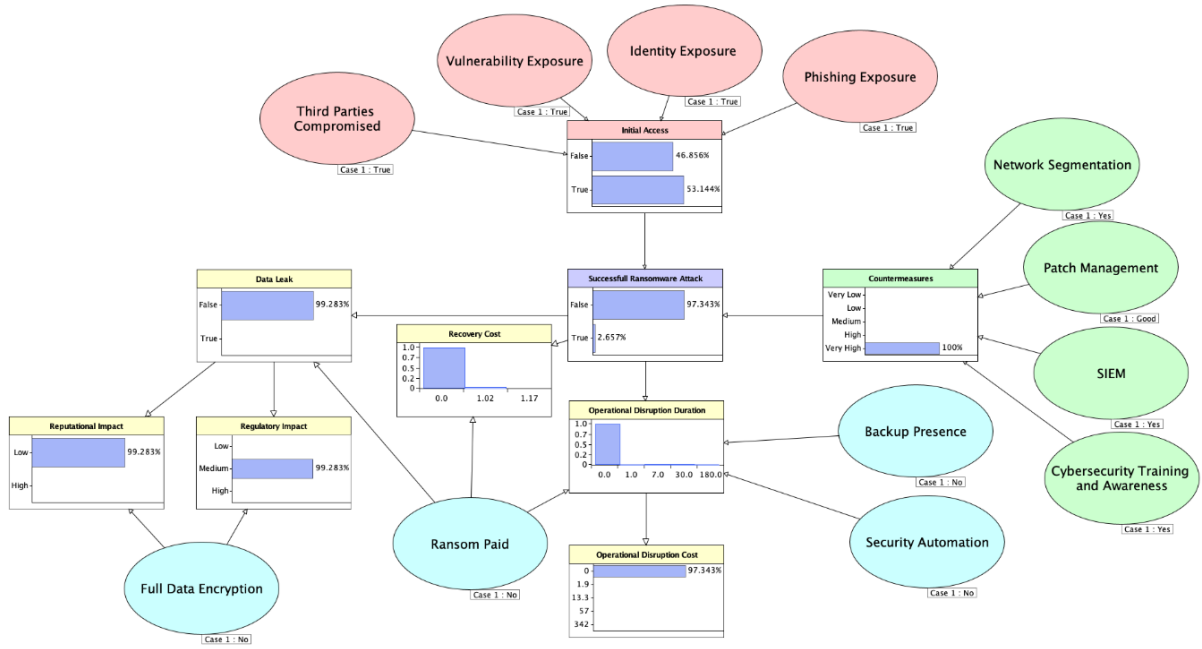


Figure B.5: Results of Scenario 2 – Prevention-Focused Organization

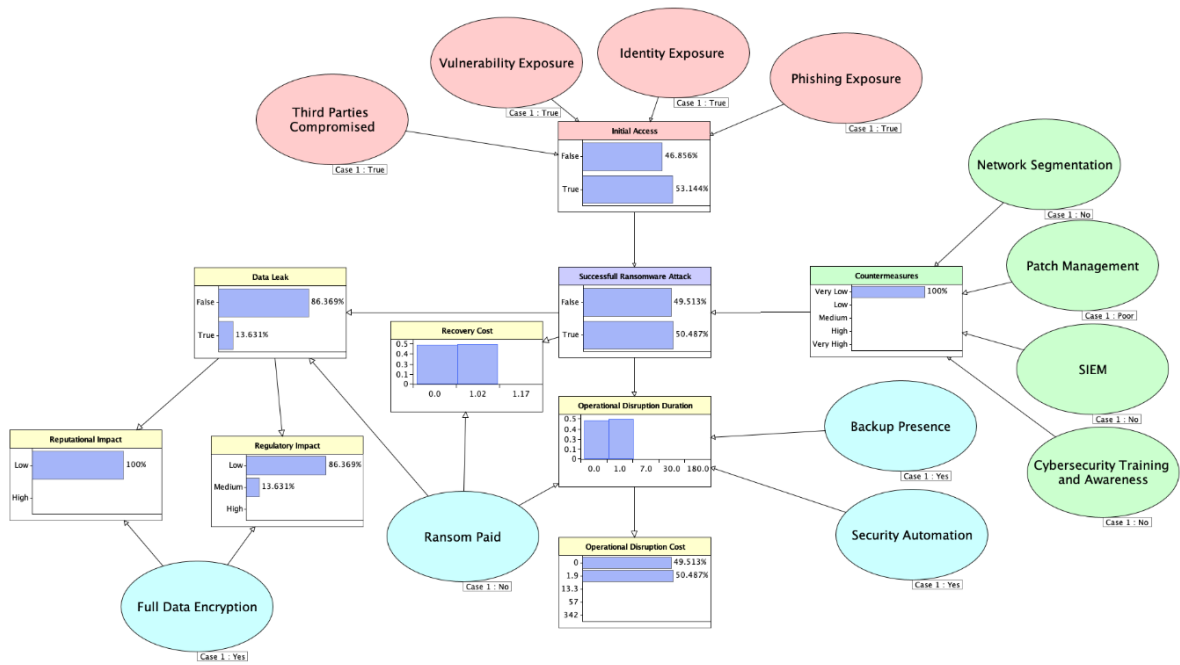


Figure B.6: Result of Scenario 2 – Resilience-Focused Organization

Q2:

	State	Resilience-Focused Configuration	Prevention-Focused Configuration	Difference (Resilience - Prevention)
Data Leak	False	86.37%	99.28%	12.91%
	True	13.63%	0.72%	-12.91%
Recovery Cost (USD million)	0	49.51%	97.34%	-48.54%
	1.02	51.49%	0.03%	-51.46%
	1.17	0%	0%	0%
Reputational Impact	Low	100%	99.28%	-0.72%
	High	0%	0.72%	-0.72%
Regulatory Impact	Low	86.37%	0%	-86.37%
	Medium	13.63%	99.28%	85.65%
	High	0%	0.72%	0.72%
Operational Disruption Duration (Days)	0	49.51%	97.34%	47.83%
	1	51.49%	0.43%	-51.06%
	7	0%	0.98%	0.98%
	30	0%	0.75%	0.75%
	180	0%	0.50%	0.50%
Operational Disruption Cost (USD million)	0	49.51%	97.34%	47.83%
	1.9	51.49%	0.43%	-51.06%
	13.3	0%	0.98%	0.98%
	57	0%	0.75%	0.75%
	342	0%	0.50%	0.50%

Table B.12: Results of Scenario 2 – Comparisons' consequences

B.3 Scenario 3- Results

Node Case Settings:

Successful Ransomware Attack	YES
Backup Presence	NO
Full Data Encryption	NO
Security Automation	NO
Ransom Paid	YES

Table B.13: Node case settings for Scenario 3

Q1-Q2-Q3:

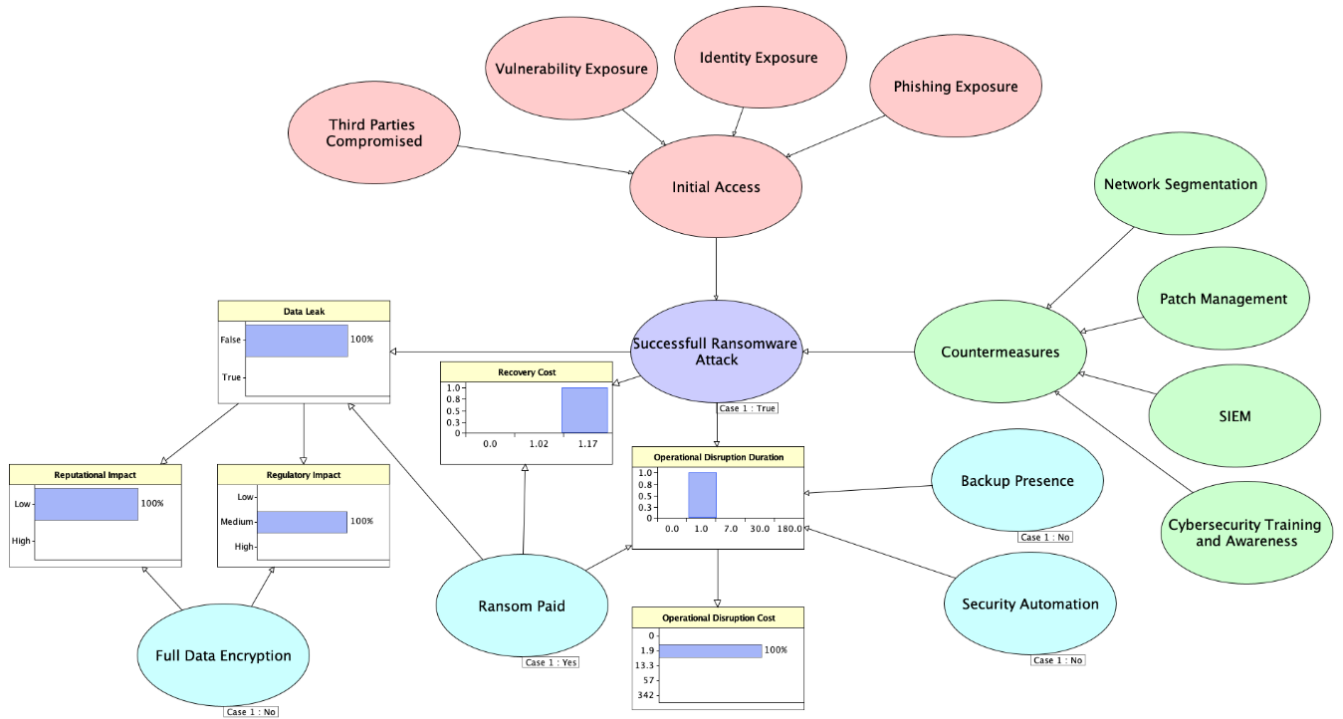


Figure B.7: Results of Scenario 3 – Ransom-paid configuration

Variable	State	Baseline	Ransom-paid	Difference (Ransom-paid-Baseline)
Data Leak	False	98.46%	100%	1.54%
	True	1.54%	0%	-1.54%
Recovery Cost (USD million)	0	91.10%	0%	-91.10%
	1.02	5.70%	0%	-5.70%
	1.17	3.20%	100%	96.80%
Reputational Impact	Low	99.05%	100%	0.05%
	High	0.05%	0%	-0.05%
Regulatory Impact	Low	37.42%	0%	-37.42%
	Medium	61.63%	100%	38.37%
	High	0.95%	0%	-0.96%
Operational Disruption Duration (Days)	0	91.10%	0%	-91.10%
	1	6.23%	100%	93.77%
	7	1.36%	0%	-1.36%
	30	0.84%	0%	-0.84%
	180	0.47%	0%	-0.47%
Operational Disruption Cost (USD million)	0	91.10%	0%	-91.10%
	1.9	6.23%	100%	93.77%
	13.3	1.36%	0%	-1.36%
	57	0.84%	0%	-0.84%
	342	0.47%	0%	-0.47%

Table B.14: Result of Scenario 3 – Comparisons' consequences

B.4 Scenario 4- Results

Case Node Settings:

Reputational Impact	HIGH
Regulatory Impact	HIGH
Operational Disruption Duration	180
Recovery Cost	1.02

Table B.15: Node case settings for Scenario 4

Q1:

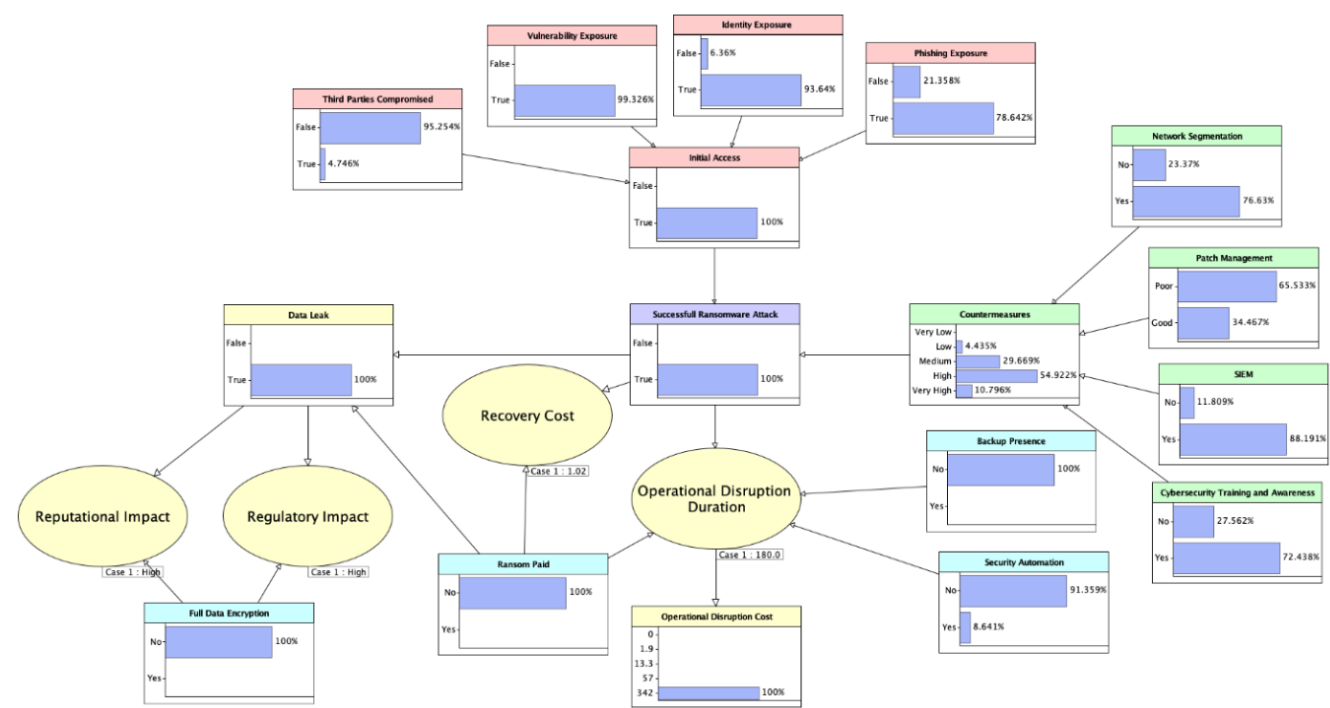


Figure B.8: Results of Scenario 4 – Reverse-analysis configuration

Variable	State	Baseline	Analysis	Difference (Analysis - Baseline)
Third Party Compromised	False	95.76%	95.26%	-0.50%
	True	4.24%	4.74%	0.50%
Vulnerability Exposure	False	1%	0.67%	-0.33%
	True	99%	99.33%	0.33%
Identity Exposure	False	9%	6.36%	-2.64%
	True	91%	93.64%	2.64%
Phishing Exposure	False	25%	21.36%	-3.64%
	True	75%	78.64%	3.64%
Initial Access	False	55.39%	0%	-55.39%
	True	44.61%	100%	55.39%
Network Segmentation	No	11.70%	23.27%	11.57%
	Yes	88.30%	76.63%	-11.57%
Patch Management	Poor	39.82%	65.53%	25.71%
	Good	60.18%	34.47%	-25.71%
SIEM	No	5.70%	11.81%	6.11%
	Yes	94.30%	88.19%	-6.11%
Cybersecurity Training & Awareness	No	14%	27.56%	13.56%
	Yes	86%	72.44%	-13.56%
Countermeasures	Very Low	0.003%	0.18%	0.177%
	Low	1.18%	4.43%	3.25%
	Medium	11.84%	29.67%	17.83%
	High	43.85%	54.92%	11.07%
	Very High	43.10%	10.80%	-32.20%
Successful Ransomware Attack	False	91.10%	0%	-91.10%
	True	8.90%	100%	91.10%
Backup Presence	No	58%	100%	42%
	Yes	42%	0%	-42%
Security Automation	No	69%	91.36%	22.36%
	Yes	31%	8.64%	-22.36%
Ransom Paid	No	64%	100%	36%
	Yes	36%	0%	-36%
Full Data Encryption	No	62%	100%	38%
	Yes	38%	0%	-38%

Table B.16: Result of Scenario 4 – Comparisons' consequences

List of Figures

Figure A.1: Bayesian Network	10
Figure B.1: Baseline scenario of the Bayesian Network	23
Figure B.2: Results of Scenario 1 - Worst-case configuration	24
Figure B.3: Result of Scenario 1 - Best-case configuration	24
Figure B.4: Results of Scenario 2 – Prevention-Focused Organization	26
Figure B.5: Result of Scenario 2 – Resilience-Focused Organization	26
Figure B.6: Results of Scenario 3 – Ransom-paid configuration	28
Figure B.7: Results of Scenario 4 – Reverse-analysis configuration	29

Bibliography

- [1] [2024 ITRC Data Breach Report](#)
- [2] [Claroty, State of CPS security: Healthcare Exposures 2025](#)
- [3] [2025 SpyCloud Identity Exposure Report](#)
- [4] [2021 State of the Phish](#)
- [5] [HHS HC3: White Paper](#)
- [6] [M-Trends 2025](#)
- [7] [HHS Hospital Cyber Resiliency Initiative: Landscape Analysis](#)
- [8] [Becker Hospital Review](#)
- [9] [Sophos, The State of Ransomware in Healthcare 2025](#)
- [10] [2021 HIMSS Healthcare Cybersecurity Survey](#)
- [11] [IBM, Cost of a Data Breach Report 2024](#)
- [12] [GDPR](#)